

Clase 012 — DNS, DHCP y ARP: funcionamiento y riesgos

Parte: **0 — Fundamentos y prerequisites** · Fuente: RFC 1035 (DNS), RFC 2131 (DHCP), RFC 826 (ARP)

 Duración estimada: **100 min** · Nivel: **Fundamentos**

Objetivo

Comprender los tres protocolos de infraestructura que hacen funcionar cualquier red local e Internet: DNS (resolución de nombres), DHCP (asignación de direcciones) y ARP (mapeo IP↔MAC). Todos comparten un problema: se diseñaron sin autenticación, lo que los convierte en vectores clásicos de ataque en red local.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** el proceso de resolución DNS y sus tipos de registro.
2. **Explicar** el intercambio DHCP (DORA) y su ausencia de autenticación.
3. **Detallar** cómo ARP resuelve MAC a partir de IP.
4. **Identificar** ataques: ARP spoofing, DNS spoofing, DHCP rogue.
5. **Observar** y detectar estos ataques en el laboratorio.

Temas

#	Tema	Por qué importa
1	Resolución DNS	Cómo un nombre se vuelve una IP
2	Tipos de registro	A, AAAA, CNAME, MX, TXT, NS
3	Caché y recursión	Rendimiento y superficie de envenenamiento
4	DHCP DORA	Discover, Offer, Request, Ack
5	ARP	Puente entre capa 3 y capa 2
6	ARP spoofing	Base del MITM en LAN
7	DNS/DHCP rogue	Redirección y control del tráfico
8	Defensas	DHCP snooping, DAI, DNSSEC

Definiciones y características

- **DNS:** sistema jerárquico que traduce nombres a IPs. Clave: usa UDP/53 (y TCP para transferencias); sin DNSSEC, las respuestas no están autenticadas.
- **Registro A / AAAA:** mapea un nombre a IPv4 / IPv6. Clave: el registro más consultado.

- **DHCP DORA:** Discover, Offer, Request, Acknowledge. Clave: el cliente confía en el primer servidor que responde → servidor rogue.
- **ARP:** resuelve una IP local a su MAC mediante broadcast. Clave: sin estado ni autenticación; cualquiera puede responder.
- **ARP spoofing:** enviar respuestas ARP falsas para asociar tu MAC a la IP de la víctima/gateway. Clave: habilita MITM.
- **DNSSEC:** extensión que firma las respuestas DNS. Clave: mitiga el envenenamiento, no la confidencialidad.

Herramientas y preparación

En Kali: `dig`, `nslookup`, `arp`, `ip neigh`, `dhclient`, y para prácticas ofensivas de laboratorio **ettercap** o **bettercap** y `arpspoof` (`dsniff`). Wireshark para observar. Necesitas al menos tres nodos en tu red interna: atacante, víctima y gateway/servidor.

Laboratorio guiado

1. Consultas DNS:

```
bash dig A example.com +short dig MX example.com dig +trace example.com # observa la resolución jerárquica
```

2. Ver la caché ARP de tu equipo:

```
bash ip neigh show
```

Anota la MAC del gateway. 3. **Observar DHCP.** Captura mientras renuevas la concesión en la VM:

```
bash sudo tcpdump -i eth0 -n port 67 or port 68 & sudo dhclient -v eth0
```

Identifica los cuatro mensajes DORA. 4. **ARP spoofing controlado** (solo laboratorio). Habilita el reenvío y envenena entre víctima y gateway:

```
bash echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward sudo arpspoof -i eth0 -t 10.10.10.6 10.10.10.1
```

5. **Verifica el MITM:** en la víctima, `ip neigh` mostrará ahora tu MAC asociada a la IP del gateway. Captura su tráfico en Wireshark.

6. **Detección.** En la víctima, observa entradas ARP duplicadas o cambiantes; esa es la señal del ataque.

 **Nota ética:** ARP/DNS/DHCP spoofing se practican **exclusivamente** en tu laboratorio aislado, entre tus propias VMs. Ejecutarlos en una red real ajena es interceptación ilegal de comunicaciones.

Ejercicios

1. Explica paso a paso qué ocurre desde que escribes un dominio hasta que recibes la IP.
2. Da un ejemplo de uso de cada registro: A, MX, TXT, CNAME, NS.
3. Describe cómo un servidor DHCP rogue puede convertirse en gateway de las víctimas.
4. ¿Por qué ARP es tan fácil de falsificar? ¿Qué le falta al protocolo?

5. Investiga qué son DHCP snooping y Dynamic ARP Inspection y qué ataque frena cada uno.
6. Explica qué protege DNSSEC y qué **no** protege (pista: confidencialidad).

Reto verificable

Monta en tu laboratorio un ataque de ARP spoofing entre dos VMs y **demuéstralo con evidencia**: captura la tabla ARP de la víctima antes y después, y muestra en Wireshark tráfico de la víctima pasando por el atacante. Después, describe una defensa que lo habría impedido.

Criterio de aceptación: la tabla ARP de la víctima muestra la MAC del atacante asociada a la IP del gateway tras el ataque, y hay una captura que evidencia el tráfico interceptado. La sección de defensa nombra un control real (DAI, ARP estático) y explica por qué funciona.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El ARP spoofing corta la conexión de la víctima	No habilitaste <code>ip_forward</code> . Actívalo para reenviar el tráfico.
<code>dig</code> devuelve SERVFAIL	Resolver mal configurado o DNSSEC fallando. Prueba otro servidor con <code>@</code> .
La víctima no cae en el spoofing	Tiene ARP estático o DAI. Es la defensa funcionando.
No veo los 4 mensajes DHCP	La concesión aún es válida; fuerza <code>dhclient -r</code> y renueva.
DNS spoofing no redirige	La víctima usa DoH/DoT o caché. Considera el cifrado del canal DNS.

Preguntas frecuentes

¿Por qué estos protocolos no tienen autenticación? Se diseñaron en los años 80 para redes confiables. Añadir seguridad después (DNSSEC, DAI) es más difícil que haberla incluido de origen; es una lección de diseño.

¿DNS over HTTPS (DoH) resuelve todo? Añade confidencialidad e integridad del canal cliente-resolver, dificultando el spoofing y la vigilancia, pero no autentica la zona como DNSSEC ni protege dentro de la LAN por sí solo.

¿ARP spoofing funciona en redes conmutadas modernas? Sí, porque explota la ausencia de autenticación de ARP, no el medio. Las mitigaciones son a nivel de switch (DAI) y segmentación.

¿Cómo detecto un servidor DHCP rogue? Monitorizando ofertas DHCP inesperadas y con DHCP snooping en switches, que solo confía en puertos autorizados.

Referencias

- RFC 1035 (DNS) — <https://www.rfc-editor.org/rfc/rfc1035>
- RFC 2131 (DHCP) — <https://www.rfc-editor.org/rfc/rfc2131>
- RFC 826 (ARP) — <https://www.rfc-editor.org/rfc/rfc826>

- Cloudflare Learning: DNS — <https://www.cloudflare.com/learning/dns/what-is-dns/>

Siguiente clase

Clase 013 - HTTP, HTTPS y la arquitectura de la web moderna